

Битва алгоритмов: ИИ на службе Red Team и Blue Team. Как нейросети меняют ландшафт кибербезопасности Беларуси

 redsec.by/article/bitva-algoritmov-ii-na-sluzhbe-red-team-i-blue-team-kak-nejroseti-menyayut-landshaft-kiberbezopasnosti-belarusi

Red Teams | 13 января 2026



Тема искусственного интеллекта (ИИ) сегодня находится на пике глобального хайпа, однако в профессиональных кругах обсуждения часто сводятся к генерации картинок или текстов. В сфере информационной безопасности (ИБ) ситуация иная. Здесь ИИ давно перестал быть футуристическим концептом или маркетинговой уловкой. Это мощное, обоюдоострое оружие, реально применяемое как атакующими (Red Team), так и защитниками (Blue Team).

Для белорусского бизнеса, особенно для организаций, подпадающих под регуляторные требования Оперативно-аналитического центра при Президенте Республики Беларусь (ОАЦ), игнорирование этого фактора становится критическим риском. Мы стоим на пороге новой эры, где скорость реакции человека уже недостаточна. Давайте разберем детально, как нейросети трансформируют методы взлома и защиты, и почему 2026–2027 годы станут переломными.

Red Team AI: Эволюция угрозы. Как атакующие используют Machine Learning

Традиционный хакинг требовал времени, глубоких знаний и ручного труда. Использование генеративного ИИ (GenAI) и больших языковых моделей (LLM)

позволило злоумышленникам автоматизировать сложные процессы, снизив порог входа и многократно увеличив масштаб атак.

1. Социальная инженерия 2.0: Фишинг, который невозможно отличить

Классический фишинг часто выдавал себя плохой грамматикой, нелогичными оборотами или визуальными артефактами. Сегодня этот барьер сломлен.

Представьте ситуацию: злоумышленник не просто отправляет типовое письмо. Нейросеть скормливает себе гигабайты публичной и утекшей переписки вашего генерального директора. Она анализирует синтаксис, специфический сленг, частоту использования эмодзи, характерные обороты и даже время отправки сообщений. На выходе хакер получает черновик письма, которое выглядит абсолютно аутентично — так, словно его писал ваш босс. Это выводит **Business Email Compromise (BEC)** на пугающий уровень эффективности.

Инструментарий теневого рынка

На даркнет-форумах и в закрытых Telegram-каналах активно распространяются специализированные инструменты:

- **WormGPT и FraudGPT** — это модифицированные ("jailbroken") версии популярных LLM. В отличие от ChatGPT или Claude, у них сняты этические фильтры и ограничения безопасности (guardrails).
- Эти системы способны свободно генерировать убедительные фишинговые сценарии, писать код для эксплойтов и создавать полиморфные тела писем, обходящие спам-фильтры.

Статистика IBM Security Research: В ходе контролируемых экспериментов было доказано, что искусственному интеллекту потребовалось всего **5 промптов и 5 минут**, чтобы создать фишинговую кампанию, сопоставимую по эффективности с той, которую команда людей-экспертов разрабатывала **16 часов**.

Более того, за этот короткий промежуток ИИ сгенерировал не только текст, но и полностью функциональные фишинговые страницы (landing pages), визуально копирующие корпоративные порталы входа.

Как следствие, в период с 2024 по 2025 год мы наблюдаем **рост фишинг-атак с использованием GenAI на 1265%**. Для белорусских CISO и начальников отделов безопасности это означает смену парадигмы: каждый третий-пятый инцидент социальной инженерии теперь создан машиной, которая не допускает человеческих ошибок.

2. Автоматизированный поиск Zero-Day уязвимостей

Второй вектор, где Red Team получает преимущество — это фаззинг и анализ исходного кода. Раньше поиск уязвимостей нулевого дня (zero-day) был делом элитных исследователей, тратящих месяцы на реверс-инжиниринг. Теперь нейросети масштабируют этот процесс.

В октябре 2024 года Google продемонстрировал возможности системы **Big Sleep** (ранее известной как Project Naptime). Это специализированный ИИ-агент, который совершил исторический прорыв: он самостоятельно обнаружил эксплуатируемую уязвимость переполнения буфера в стеке (stack buffer overflow) в базе данных **SQLite**.

Ключевые особенности кейса:

- Система анализирует исходный код и изменения в репозиториях.
- ИИ проводит динамическое тестирование, моделируя атаки.
- Уязвимость была найдена в ветке разработки до релиза в продакшн.

Хотя в данном примере технология служила "белым" целям, аналогичные инструменты уже есть у киберпреступных групп. В 2025 году Check Point Research зафиксировал появление **45 новых хакерских группировок**, многие из которых используют автоматизированные сканеры на базе ML. Доля уязвимостей, затрагивающих корпоративные технологии (облака, Active Directory, виртуализация), составляет 44%, и многие из них находятся машинами.

3. Полиморфный вредоносный код: Мутация в реальном времени

Самый опасный тренд — это использование ИИ для обфускации и модификации кода вредоносного ПО (Malware) "на лету".

Концепция: Обычный вирус имеет фиксированную сигнатуру (уникальный набор байтов). Антивирус сравнивает файл с базой данных сигнатур и блокирует совпадения. Полиморфный вирус меняет свой код, но сохраняет функционал. ИИ-полиморфный вирус делает это непрерывно и непредсказуемо.

Примером служит **BlackMamba** — proof-of-concept малварь, представленная исследователями в 2023 году.

- Она использует внешний API генеративной модели (похожей на GPT).
- При каждом запуске или распространении на новый хост, вирус запрашивает у нейросети новый вариант своего кода (кейлоггера или дроппера).
- Полученный код динамически компилируется и исполняется в памяти, не касаясь диска (fileless attack).

Результаты тестирования против современных EDR-систем (Endpoint Detection and Response) шокируют: **100% evasion rate** (уровень обхода защиты). Даже после попытки дообучить защитные модели (adversarial training), эффективность обнаружения улучшилась лишь незначительно, оставив 70% пропусков атак. Это делает классические сигнатурные антивирусы практически бесполезными против атак нового поколения.

Blue Team AI: Скорость машины против скорости машины

Если атакующая сторона использует ИИ для *масштабирования* и *маскировки*, то защитники (Blue Team) используют его для *скорости* и *глубины анализа*. В условиях, когда время от проникновения до шифрования данных измеряется минутами, человек физически не успевает реагировать.

1. Автономная защита (NDR): Реакция пока вы спите

Системы класса **NDR (Network Detection and Response)**, такие как **Darktrace Antigena**, стали первыми примерами полностью автономного ИИ в кибербезопасности. Они не ждут команды оператора SOC (Security Operations Center), а действуют самостоятельно.

Кейс: City of Las Vegas Сотрудник муниципалитета открыл спифишинг-письмо. Традиционные средства защиты (периметральные фаерволы) пропустили угрозу.

- **Этап А (Аномалия):** ИИ заметил нехарактерное поведение устройства сразу после открытия письма.
- **Этап R (Ransomware):** Когда вредонос попытался начать шифрование и горизонтальное перемещение по сети, традиционные антивирусы только начали формировать алерты.
- **Реакция:** Antigena сработала хирургически. Она заблокировала конкретные подозрительные соединения зараженного компьютера, но не отключила его от сети полностью, позволив сотруднику продолжить безопасную работу. Распространение шифровальщика было остановлено за секунды.

Кейс: Японская консалтинговая фирма Хакеры скомпрометировали IoT-устройство — подключенную к интернету камеру видеонаблюдения, используя ее как точку входа (Pivot point). ИИ обнаружил аномальный объем исходящего трафика с камеры на внешний сервер (exfiltration). Система заблокировала передачу данных, но оставила видеопоток рабочим.

2. SIEM нового поколения: От шума к смыслу

Главная проблема классических SIEM-систем (Security Information and Event Management) — это огромное количество ложных срабатываний (False Positives).

Аналитик SOC может получать тысячи уведомлений в день, 99% из которых — информационный шум. Это приводит к "Alert Fatigue" (усталости от уведомлений), из-за которой реальные инциденты пропускаются.

ИИ в современных SIEM (например, решения на базе Splunk, QRadar, Elastic Security с ML-модулями) меняет правила игры.

Пример внедрения в Raiffeisen Bank International:

- **Контекстный анализ:** Система не просто сообщает "Обнаружен вирус", а коррелирует это с данными Threat Intelligence, историей пользователя и статусом хоста.
- **Экономия ресурсов:** Банк сэкономил 24 часа в неделю только на процессе тестирования защиты против новых угроз.
- **Снижение False Positives:** ИИ фильтрует легитимные аномалии, оставляя для внимания человека только верифицированные инциденты.

Для белорусских субъектов хозяйствования это критически важно в свете **Указа № 60** и приказов ОАЦ. Требование о передаче информации об инцидентах в Национальный центр кибербезопасности (НЦКБ) подразумевает, что вы *видите* эти инциденты. ИИ-SIEM позволяет не только видеть, но и генерировать автоматизированные сценарии реагирования (SOAR): блокировать IP, изолировать хост, собирать форензику.

3. UEBA: Поведенческий анализ вместо подписей

Поведенческая аналитика (User and Entity Behavior Analytics, UEBA) — это краеугольный камень современной защиты. ИИ "обучается" нормальной жизни сети:

- Во сколько бухгалтер приходит на работу?
- К каким серверам обращается администратор?
- Какой объем трафика генерирует принтер?

Любое отклонение от этого "базового профиля" (baseline) становится триггером.

Индикаторы, невидимые для сигнатур, но видимые для ИИ:

- Сотрудник, обычно работающий с 9:00 до 18:00, начинает выгрузку больших объемов данных в 03:00 ночи.
- Сервер баз данных инициирует исходящее соединение на редкий внешний IP с самоподписанным сертификатом.
- Рабочая станция начинает массовое сканирование портов во внутренней сети (Lateral Movement).

По отдельности эти события могут казаться легитимными, но корреляция слабых сигналов через ML позволяет выявить сложную атаку на ранней стадии.

Три простые аналогии для понимания сути конфликта

Чтобы донести сложность ситуации до руководства (СЕО, совет директоров), используйте эти аналогии.

Аналогия 1: Письмо от друга (Социальная инженерия)

- **Red Team AI:** Вор изучил переписку вашего лучшего друга: его шутки, манеру ставить смайлики, стиль речи. Он пишет вам письмо с просьбой о помощи, и вы не чувствуете подвоха, потому что "голос" друга скопирован идеально.
- **Blue Team AI:** У вас есть личный детектив-аналитик. Он читает письмо и говорит: "Стиль похож, но твой друг никогда не писал тебе в 4 утра с устройства, находящегося в Нигерии, и никогда не просил перевести деньги в криптовалюте". Детектив видит контекст, который вы упускаете.

Аналогия 2: Вирус-хамелеон (Полиморфизм)

- **Red Team AI:** Представьте вирус как опасную птицу. Раньше мы ловили их по цвету перьев (красная = опасная). Теперь это робо-птица, которая меняет цвет оперения каждую секунду. Ловец с сачком (антивирус) бесполезен — он ищет красную птицу, а она уже синяя.
- **Blue Team AI:** Новый страж не смотрит на цвет. Он смотрит на поведение: "Обычные птицы клюют зерно, а эта птица пытается перегрызть провода сигнализации". Страж хватается её, как бы она ни выглядела.

Аналогия 3: Робот-взломщик и скоростной страж (Автоматизация)

- **Red Team AI:** Грабитель принес к вашей двери робота, который перебирает миллиарды комбинаций ключей в минуту. Человек-охранник просто не успеет среагировать на такой напор.
- **Blue Team AI:** Ваш дом оборудован системой, которая замечает первую же попытку подбора и мгновенно "заливает" замочную скважину быстросохнущим бетоном, параллельно вызывая полицию. Атака блокируется быстрее, чем робот успевает перебрать 1% комбинаций.

Текущие реалии: Почему это касается Беларуси прямо сейчас?

Ситуация в 2025–2026 годах характеризуется резким обострением киберугроз в нашем регионе.

1. Пост Ransomware-группировок Несмотря на громкие операции правоохранительных органов против RaaS (Ransomware-as-a-Service), экосистема вымогателей не умерла, а фрагментировалась. Появление 45 новых групп в 2025 году говорит о том, что "свято место пусто не бывает".

2. Региональный фактор и хактивизм

Беларусь и страны СНГ находятся в зоне повышенного риска. Хакерские группы, такие как **Head Mare** и **Twelve**, используют шифровальщики не только ради выкупа, но и как инструмент саботажа и информационной войны (wiper attacks). Их цель — уничтожение инфраструктуры.

3. Технический всплеск

Лаборатория Касперского фиксирует **500,000 новых вредоносных файлов ежедневно** (+7% год к году). Важно понимать: это не просто "новые вирусы", это потенциально ИИ-модифицированные варианты, которые проходят сквозь устаревшие системы защиты как нож сквозь масло.

4. Риски цепочки поставок (Supply Chain)

Инцидент с российской ИТ-компанией **Positive Technologies** (взлом инфраструктуры разработки китайской группировкой APT в первой половине 2025 года) — это тревожный звонок. Компрометация поставщика ПО означает, что "зараженным" может оказаться легальное обновление софта, которое устанавливают десятки белорусских компаний. В таких случаях классические средства защиты слепы, так как доверяют подписанному сертификатом ПО. Поведенческий анализ (Blue Team AI) — единственный способ заметить, что легальный процесс update.exe начал вести себя вредоносно.

Стратегия выживания: Action Plan для белорусского бизнеса

Для соблюдения требований ОАЦ и обеспечения реальной безопасности, компаниям необходимо пересмотреть свои бюджеты и стратегии.

- **Сдвиг фокуса на поведенческий анализ.**

Перестаньте полагаться только на антивирусные базы. При выборе **SIEM**, **EDR/XDR** и **NGFW**, ставьте жесткое требование поставщикам: наличие модулей Machine Learning для выявления аномалий. Система должна отвечать на вопрос "Что делает этот процесс?", а не "Есть ли этот файл в черном списке?".

- **Запрос AI-функционала в тендерах.** При закупке средств защиты информации (СЗИ) прямо спрашивайте вендора: "Как ваше решение использует ИИ для снижения уровня шума и детекции Zero-Day?". Если ответа нет — решение устарело.

- **Переобучение персонала (Security Awareness).**

Тренинги по фишингу, где сотрудников учат искать опечатки, больше не работают. Фишинг теперь грамматически идеален. Обучайте сотрудников **контекстной бдительности**: "Почему запрос пришел сейчас?", "Свойственно ли это отправителю?", "Почему меня торопят?".

- **Real-Time Incident Response.** Если у вас есть SOC (внутренний или на аутсорсинге), убедитесь, что у него есть полномочия и техническая возможность блокировать угрозы автономно. В эпоху ИИ-атак время реакции человека (анализ -> доклад -> решение -> действие) является непозволительной роскошью.
- **Проактивное соответствие ОАЦ.** Аттестация системы защиты информации — это не просто бумажная работа. Это процесс, который заставляет вас инвентаризировать активы и понимать потоки данных. Используйте требования регулятора как фреймворк для построения реальной защиты, внедряя современные средства контроля, адекватные угрозам 2026 года.

Искусственный интеллект на службе Red Team — это реальность, которая сделала кибератаки быстрее, умнее и дешевле для преступников. Но ИИ на службе Blue Team — это наш асимметричный ответ.

Белорусские компании, которые осознают эту динамику и инвестируют в *AI-enhanced* защиту, получают двойное преимущество: они надежно защищают свои коммерческие тайны и персональные данные клиентов, а также обеспечивают соответствие жестким стандартам информационной безопасности, которые становятся обязательными в 2025–2026 годах. В этой гонке вооружений побеждает не тот, у кого больше ресурсов, а тот, чей ИИ быстрее принимает решения.